

DocChat AI

COMPLIANCE & SECURITY ASSESSMENT PACK

BAA + Security Assessment & CAIQ Mapping

Business Associate Agreement | Vendor Security Questionnaire | CAIQ

CONTENTS

Part 1 — Business Associate Agreement (BAA) Template

Part 2 — Security Assessment Questionnaire

Part 3 — CAIQ Targeted Mapping

Part 4 — Incident Response Plan

Part 5 — Security Assertions & Proof Pack Structure

CONFIDENTIAL — Legal review required. Not legal advice.

DocChat AI | Version 1.0 | May 2026

PART 1: Business Associate Agreement (BAA) — Template

This BAA is entered into between Customer ("Covered Entity") and DocChat AI ("Business Associate").

Legal review required — this is a template, not legal advice. Adjust jurisdiction, indemnification, and liability caps with qualified legal counsel.

1.1 Permitted Uses and Disclosures

Business Associate may use or disclose Protected Health Information (PHI) only as necessary to perform document analysis services during an active session. PHI is not retained after session termination.

1.2 Minimum Necessary Standard

Business Associate limits PHI exposure strictly to the minimum necessary to perform processing during an active session. No PHI is accessed beyond what is required for immediate inference.

1.3 No Persistence Clause

Business Associate does not create, receive, maintain, or transmit PHI beyond transient in-memory processing required to fulfill a request. No PHI is retained post-session.

1.4 Safeguards

Business Associate implements administrative, physical, and technical safeguards compliant with HIPAA Security Rule (45 CFR 164.308-326), including:

- TLS 1.2+ encryption for all PHI transmissions in transit
- Zero-retention architecture — no disk or database storage of PHI
- Session-scoped memory only — isolated per user session

1.5 Breach Definition & Reporting

Breach defined per 45 CFR §164.402. Business Associate reports to Covered Entity any confirmed security incident involving PHI within 48 hours of discovery, including scope, impact, and remediation steps.

1.6 Subcontractors

Business Associate ensures any subcontractor (specifically NVIDIA NIM API) agrees to equivalent restrictions. Subcontractors receive no stored PHI — only in-transit session text for inference purposes only.

1.7 Availability

This BAA is available exclusively to Business Plan customers. Contact support.docchatai@proton.me to initiate BAA execution.

1.8 Termination

BAA terminates when Customer ceases use of DocChat AI services or upon written notice. Due to zero-retention architecture, no PHI remains in possession of Business Associate upon termination.

Covered Entity: _____

DocChat AI: _____

Signature: _____

Date: _____

PART 2: Security Assessment Questionnaire

For enterprise vendor risk reviews (compatible with CAIQ, SIG, or custom security questionnaire formats).

Section A: Data Handling

Question	DocChat AI Response
A1 — Where is customer data stored?	Nowhere persistent. Only in ephemeral session memory (RAM). Deleted on session end.
A2 — Retention period after session ends?	0 seconds. Immediate deletion via memory deallocation.
A3 — Backup retention?	Not applicable. No backups contain customer data. No persistence.
A4 — Data classification?	PHI: Allowed (Business Plan, ephemeral only). PII: Processed, not retained. Documents: Not stored.

Section B: Access Control

Question	DocChat AI Response
B1 — SSO supported?	Yes — Google, Microsoft Entra ID (Business Plan).
B2 — MFA required?	Yes — enforced for all internal DocChat AI infrastructure.
B3 — Employee access to customer data?	Impossible — no persisted customer data exists by architectural design.
B4 — RBAC enforced?	Yes — for all internal systems. Least privilege model applied.

Section C: Encryption

Question	DocChat AI Response
C1 — Data in transit?	TLS 1.2+ (AES-256-GCM, ECDHE). Perfect Forward Secrecy enabled.
C2 — Data at rest?	Not applicable — no customer data is stored at any layer.
C3 — Key management?	Automatic session keys via TLS handshake. Ephemeral per connection.

Section D: Subprocessors

Subprocessor / Function / Data / Location	
NVIDIA NIM API — Document inference	Session text fragments only. No storage. AWS us-east-1.
No other subprocessors	DocChat AI does not share data with any other third parties.

Section E: Certifications & Audits

Question	DocChat AI Response
E1 — SOC2 Type II?	Controls aligned with SOC2 Type II. Formal audit documentation available on request.
E2 — Penetration testing?	Annual third-party pentest. Report available under NDA.
E3 — HIPAA?	HIPAA-ready configuration + BAA available for Business Plan customers.

Section F: Incident Response

Question	DocChat AI Response
F1 — IR plan available?	Yes — shared under NDA on request.
F2 — Breach notification?	48 hours for confirmed incidents involving PHI or customer data in transit.

Section G: Infrastructure

Question	DocChat AI Response
G1 — Hosting environment?	Serverless/stateless runtime (Vercel / cloud infrastructure).
G2 — Data residency?	Not applicable — no persistent customer data. Inference region: US-East.
G3 — RBAC + least privilege?	Yes — enforced. Credential rotation automated.

PART 3: CAIQ — Consensus Assessments Initiative Questionnaire Mapping

High-signal CAIQ subset with DocChat AI responses. Covers the categories most scrutinized in enterprise security reviews.

A. Data Security & Information Lifecycle (AIS/DSP)

Control	DocChat AI Answer
AIS-01: Data inventory	No customer docs or derived content stored. Ephemeral session memory only.
DSP-01: Retention duration	0 seconds post-session termination.
DSP-03: Data disposal	Automatic memory deallocation at session end. No persistent copies.

B. Encryption & Key Management (EKM)

Control	DocChat AI Answer
EKM-02: Encryption in transit	TLS 1.2+ (ECDHE, AES-256-GCM). Verifiable via SSL Labs.
EKM-03: Encryption at rest	Not applicable — no data stored. Consistent across all documentation.
EKM-07: Key management	Ephemeral session keys via TLS handshake. No long-term key storage for customer data.

C. Identity & Access Management (IAM)

Control	DocChat AI Answer
IAM-01: User authentication	SSO via Google / Microsoft Entra ID (Business Plan).
IAM-03: MFA	Enforced for internal systems; delegated to IdP for enterprise users.
IAM-06: Privileged access	No access to customer data possible — architectural constraint, not policy.

D. Infrastructure & Virtualization (IVS)

Control	DocChat AI Answer
IVS-01: Environment separation	Stateless per-session isolation. No cross-session data sharing.
IVS-06: Hardening	Minimal runtime surface (serverless/stateless). No unnecessary services.

E. Application Security (AIS)

Control	DocChat AI Answer
AIS-05: Secure development	Mandatory code review. Automated dependency scanning.
AIS-06: Vulnerability management	Continuous dependency monitoring. Patch cycle enforced.

F. Logging & Monitoring (LOG)

Control	DocChat AI Answer
LOG-01: Logging scope	Metadata only: timestamps, token counts, errors. No content logged.
LOG-02: Log protection	Logs contain no sensitive data by design. Content exclusion architectural.

G. Incident Management (IR)

Control	DocChat AI Answer
IR-01: IR plan	Defined IR lifecycle: detect, contain, investigate, notify, remediate.
IR-02: Breach notification	48 hours for confirmed incidents. Scope + impact + remediation communicated.

H. Third-Party Management (TPM)

Control	DocChat AI Answer
TPM-01: Subprocessors	NVIDIA NIM API only. Full subprocessor list disclosed.
TPM-02: Data sharing	Minimal text fragments only. No storage or reuse per agreement/provider terms.

PART 4: Incident Response Plan	
Phase	Actions
1. Detection	System monitoring alerts; anomaly detection (traffic/errors); third-party notifications
2. Classification	S1: potential data exposure S2: service disruption S3: non-critical anomaly
3. Containment	Isolate affected service; terminate active sessions if required; revoke credentials/tokens
4. Investigation	Analyze logs (non-content metadata only); trace request lifecycle; validate system boundaries
5. Notification	Enterprise customers notified within 48 hours: scope + impact + remediation steps

6. Eradication	Patch vulnerability; rotate keys; deploy fix
7. Recovery	Restore service; monitor stability
8. Post-incident	Internal review; control improvement; updated documentation

Architectural advantage: Because DocChat AI does not retain data, incident impact is inherently limited to in-transit exposure scenarios only. No stored data can be exfiltrated.

PART 5: Security Assertions & Proof Pack Summary

The following assertions are enforced through system architecture, not policy alone:

Assertion	Enforcement Mechanism
Zero data retention	No storage interfaces; no write operations; code-verifiable
No content logging	Log configuration excludes content fields; log samples available
No training usage	Architectural — data never persisted to training pipelines
No insider access	Impossible — no stored data exists anywhere in system
No third-party sharing	Single subprocessor (NVIDIA NIM); ephemeral text only; no other parties

How Zero Retention Is Enforced

Risk	Why It Cannot Happen
Data breach	No stored data exists at any layer
Insider access	Nothing to access — architectural constraint
Backup leakage	No backups contain customer data
Log leakage	No content logged — metadata only by design
Vendor misuse	Ephemeral text only; contractual restrictions on subprocessors

Contact & Documentation Requests

To request signed BAA, architecture review, penetration test summary, or SOC2 evidence package:

- Email: support.docchatai@proton.me
- Security page: <https://docchat-saas.vercel.app/security>
- Contact: <https://docchat-saas.vercel.app/contact>